

Durcissement Linux et Windows

Sécuriser un système sans casser ce qu'il fait tourner

21 HEURES

CINQUIÈME ANNÉE

76 % DE PRATIQUE



Comment ce module fonctionne

1 7 séances de 3 heures

dont 16 h les mains sur le clavier

2 Chaque séance

une manipulation qui pose le problème, la théorie qui répond, la pratique qui applique

3 2 TP notés individuels

moyenne des deux

4 Barème technique public

dès aujourd'hui



La règle du module

Une mesure de durcissement = une menace identifiée + un impact fonctionnel évalué.

Sans les deux, la mesure n'est pas justifiée et ne rapporte pas de points.



SÉANCE 1

Modèle de menace et baseline

Deux cents avertissements

Vous venez de lancer un audit sur votre machine virtuelle.

Le rapport liste deux cents problèmes.

Par lequel commencez-vous ?

C'est la seule question qui compte, et c'est le sujet du module.



Ce que durcir veut dire

Trois leviers, dans cet ordre :

1

1. Supprimer

ce qui est inutile

2

2. Restreindre

ce qui est nécessaire

3

3. Tracer

ce qui reste

Surface d'attaque

Tout point d'entrée atteignable par un acteur non autorisé.

Elle se réduit

C'est l'objectif du durcissement

Elle ne s'annule jamais

Aucun système n'est inattaquable

Ce que le durcissement ne fait pas

Pas de détection

Il ne détecte pas les intrusions

Pas de restauration

Il ne restaure pas après incident

Pas de correctifs

Il ne remplace pas les correctifs



Un serveur durci mais non patché reste vulnérable.

Modèle de menace : trois questions



Qu'est-ce qui a de la valeur ici ?

Identifier les actifs à protéger en priorité



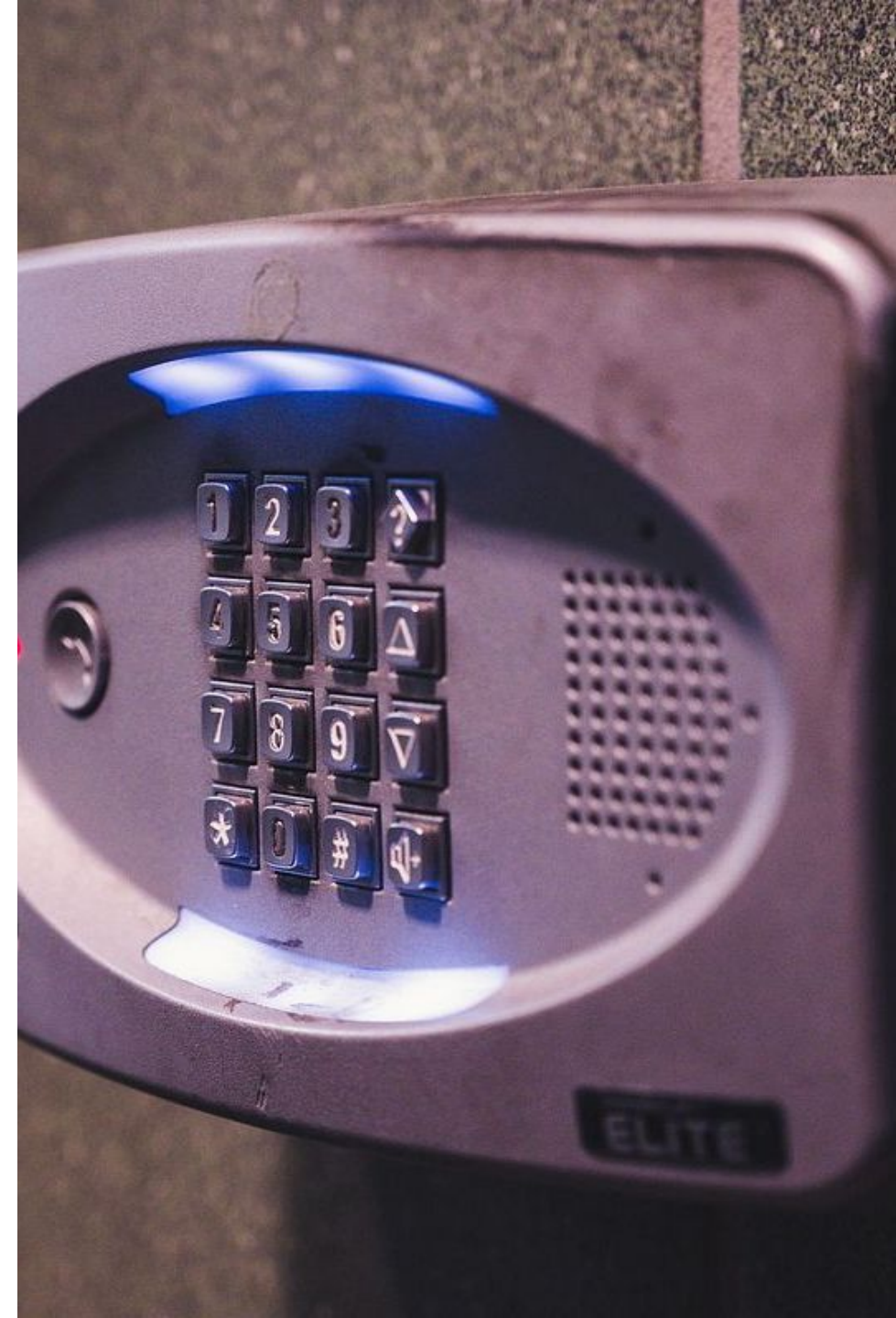
Qui voudrait l'atteindre ?

Définir les acteurs de menace pertinents



Par où passerait-il ?

Cartographier les vecteurs d'attaque possibles



Trois profils d'attaquant

Profil	Position de départ
Distant non authentifié	Aucun accès
Utilisateur local	Un compte légitime
Administrateur compromis	Les pleins pouvoirs

Une mesure contre le troisième est presque toujours moins urgente qu'une mesure contre le premier.

Baselines et référentiels

CIS

CIS (Center for Internet Security)
Benchmarks

ANSSI

ANSSI (Agence nationale de la
sécurité des systèmes
d'information) — guides français

DISA STIG

DISA STIG (Defense Information
Systems Agency — Security
Technical Implementation Guide)

Ce sont des **points de départ consensuels**. Pas des obligations contextuelles.

Les niveaux CIS



L1

acceptable dans presque tous les environnements

L2

environnements sensibles,
régressions assumées

⚠ Appliquer du L2 partout, c'est
casser la production.

Quatre principes, énoncés en 1975



Moindre privilège



Défense en profondeur

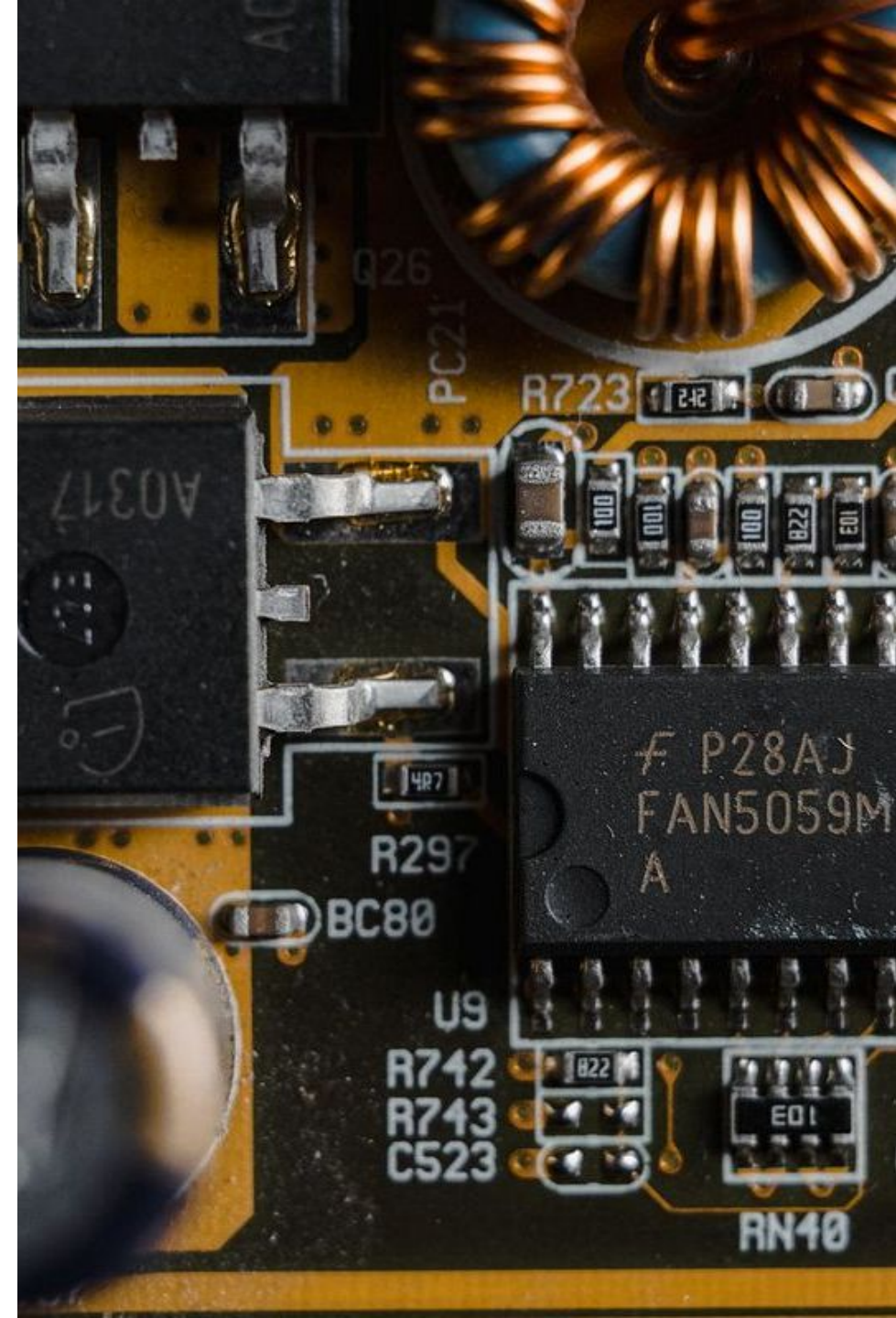


Valeurs par défaut sûres



Économie de mécanisme

Saltzer et Schroeder. Toujours exacts.



Le durcissement a un coût

Régression fonctionnelle

Des services peuvent cesser de fonctionner correctement

Charge d'exploitation

La maintenance devient plus complexe et coûteuse

Complexité

qui devient elle-même une vulnérabilité

C'est pourquoi refuser une mesure fait partie du travail.

Chiffrement de disque : ce que ça couvre

LUKS (Linux Unified Key Setup) et BitLocker

 **Protège**

un disque volé, une machine éteinte

 **Ne protège pas**

une machine allumée, un attaquant distant

C'est notre situation pendant tout le module.

SÉANCE 2

Identité et élévation sous Linux



Root est un numéro

UID (User Identifier — identifiant d'utilisateur) zéro. Pas un nom.

Un compte nommé `backup` avec l'UID 0 est root.

/etc/shadow

Le mot de passe n'y est pas chiffré. Il est **haché avec sel**.

Format Debian 12 : `$y$` — yescrypt.

Le sel empêche

les tables précalculées

Pas l'attaque

par dictionnaire

Comptes de service

Un compte qui n'ouvre jamais de session interactive n'a pas besoin d'un shell.

⊗ Lui en donner un est une faute, pas un détail.

PAM en une diapositive

PAM (Pluggable Authentication Modules — modules d'authentification enfichables)

L'authentification est déléguée à une pile de modules configurables.

auth

account

password

session

Ce qu'on ajoute dans ce module : `pam_pwquality`, `pam_faillock`

Le piège PAM

Mal placer `pam_faillock` verrouille tout le monde.

Root compris.

❌ **Faites l'instantané avant de toucher à PAM.**

sudo : le modèle

1

Qui

2

Sur quelle machine

3

En tant que qui

4

Quelle commande

Pourquoi NOPASSWD: ALL est catastrophique

C'est donner le mot de passe root.

Sans la trace.

Un seul binaire suffit

find

vi

less

awk

tar

Tous savent exécuter des commandes.

La sécurité d'une règle sudo ne dépend pas du nombre de commandes autorisées, mais de ce que chacune sait faire.



SÉANCE 3

Noyau, confinement, mémoire

Pourquoi le noyau est la cible

Il n'y a rien au-dessus de lui.

Une vulnérabilité noyau annule tous les contrôles d'accès du dessus.

Le DAC ne suffit pas

DAC (Discretionary Access Control — contrôle d'accès discrétionnaire)

Un processus hérite de tous les droits de l'utilisateur qui le lance.



Votre lecteur PDF a le droit de lire vos clés SSH (Secure Shell).

Le délégué confus

Un programme privilégié agit pour le compte d'un appelant qui ne l'est pas.

Le bit **SUID** (Set User ID — exécution sous l'identité du propriétaire du fichier) en est l'illustration canonique.

Capabilities : décomposer root

Root n'est plus monolithique. Une quarantaine de capacités distinctes.

CAP_NET_BIND_SERVICE

écouter sous le port 1024

CAP_SYS_ADMIN

la fourre-tout, quasi équivalente à root

Un serveur web n'a pas besoin d'être root pour écouter sur 80.

seccomp : réduire la surface d'appel

seccomp (secure computing mode — mode d'exécution restreint)

350

Appels système

exposés par le noyau

40

Utilisés

par un démon typique

310

Surface offerte

gratuitement à l'attaquant

Contrôle d'accès obligatoire

MAC (Mandatory Access Control — contrôle d'accès obligatoire)

La politique est imposée par le système. L'utilisateur ne peut pas y déroger.

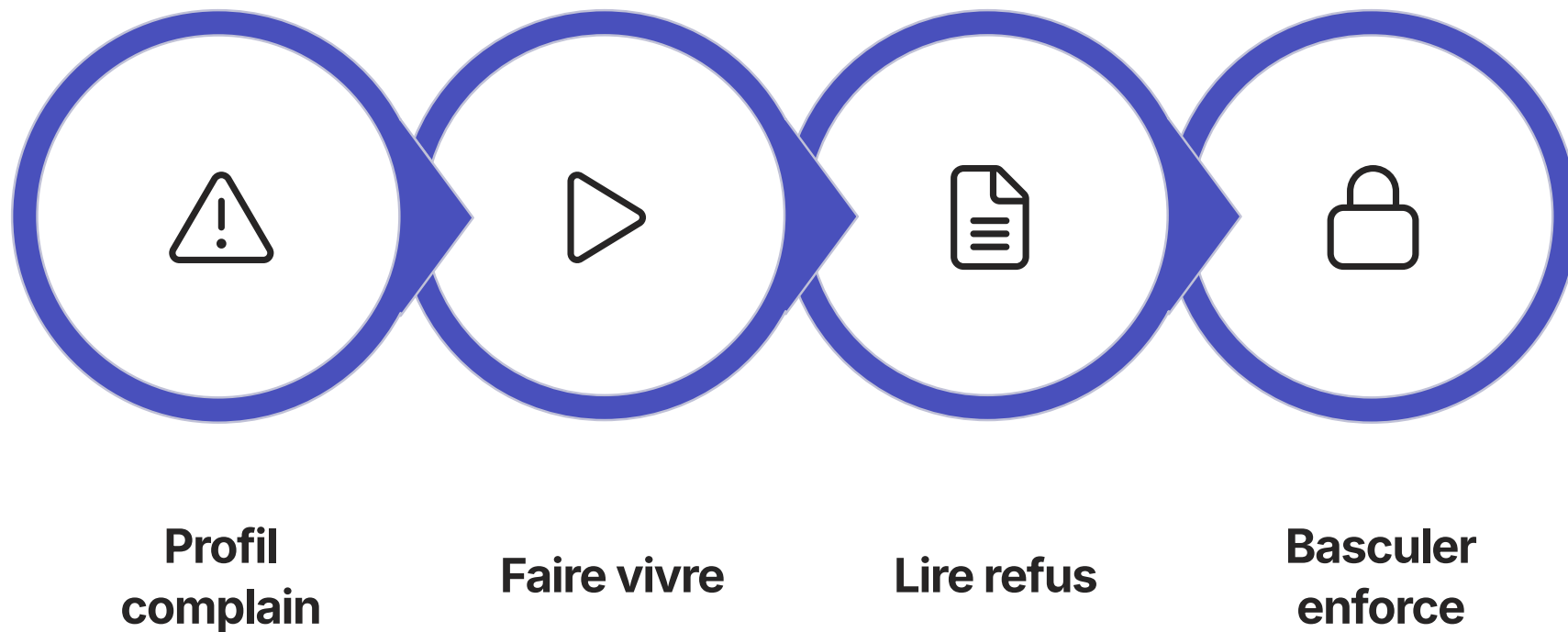
AppArmor

raisonne par chemin de fichier

SELinux

(Security-Enhanced Linux) — raisonne par étiquette

La méthode AppArmor



Jamais l'inverse.

Protections contre l'exploitation mémoire

ASLR

(Address Space Layout Randomization — randomisation de l'espace d'adressage)

KASLR

(Kernel ASLR — la même, appliquée au noyau)

NX

(No eXecute — interdiction d'exécution)

Canaris de pile

PIE

(Position Independent Executable)

RELRO

(RELocation Read-Only)

CFI

(Control Flow Integrity — intégrité du flot de contrôle)

Point important

Pas de chiffrement

Aucune de ces protections ne repose sur du chiffrement.

Pas de contrôle d'accès

Aucune ne repose sur du contrôle d'accès.

Ce sont des protections **probabilistes ou structurelles**.

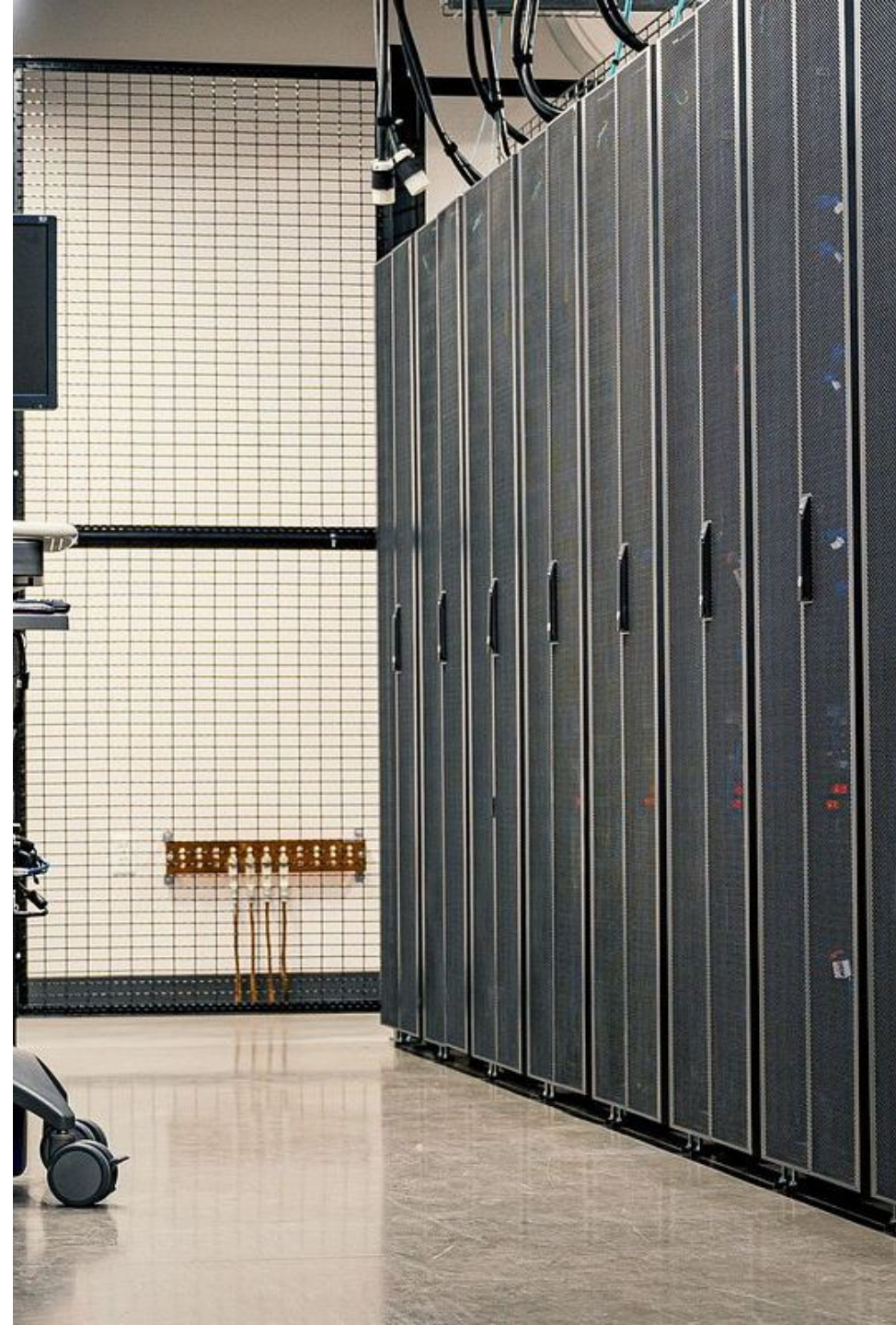
sysctl : ce que chaque ligne retire à l'attaquant

Paramètre	Ce que ça retire
randomize_va_space	La prédictibilité des adresses
kptr_restrict	Les adresses noyau en clair
dmesg_restrict	Les fuites d'information du journal
suid_dumpable	Les vidages mémoire de processus privilégiés

📄 Copier une liste trouvée en ligne sans savoir cela ne rapporte aucun point.

SÉANCE 4

Journalisation et intégrité



Deux systèmes, deux rôles

journal

événements applicatifs et système

auditd

décisions de sécurité du noyau



Ils ne se remplacent pas.

Une règle auditd répond à une question

Trop de règles produit un journal illisible et un disque plein.

Avant d'écrire une règle : quelle question d'enquête va-t-elle permettre de trancher ?

Storage=volatile

Par défaut sur une installation minimale, le journal disparaît au redémarrage.

AIDE : la bonne question

AIDE (Advanced Intrusion Detection Environment)

Vous créez une base de référence de l'état des fichiers.

Où la stockez-vous ?

⊗ Sur la machine surveillée, elle ne vaut rien.

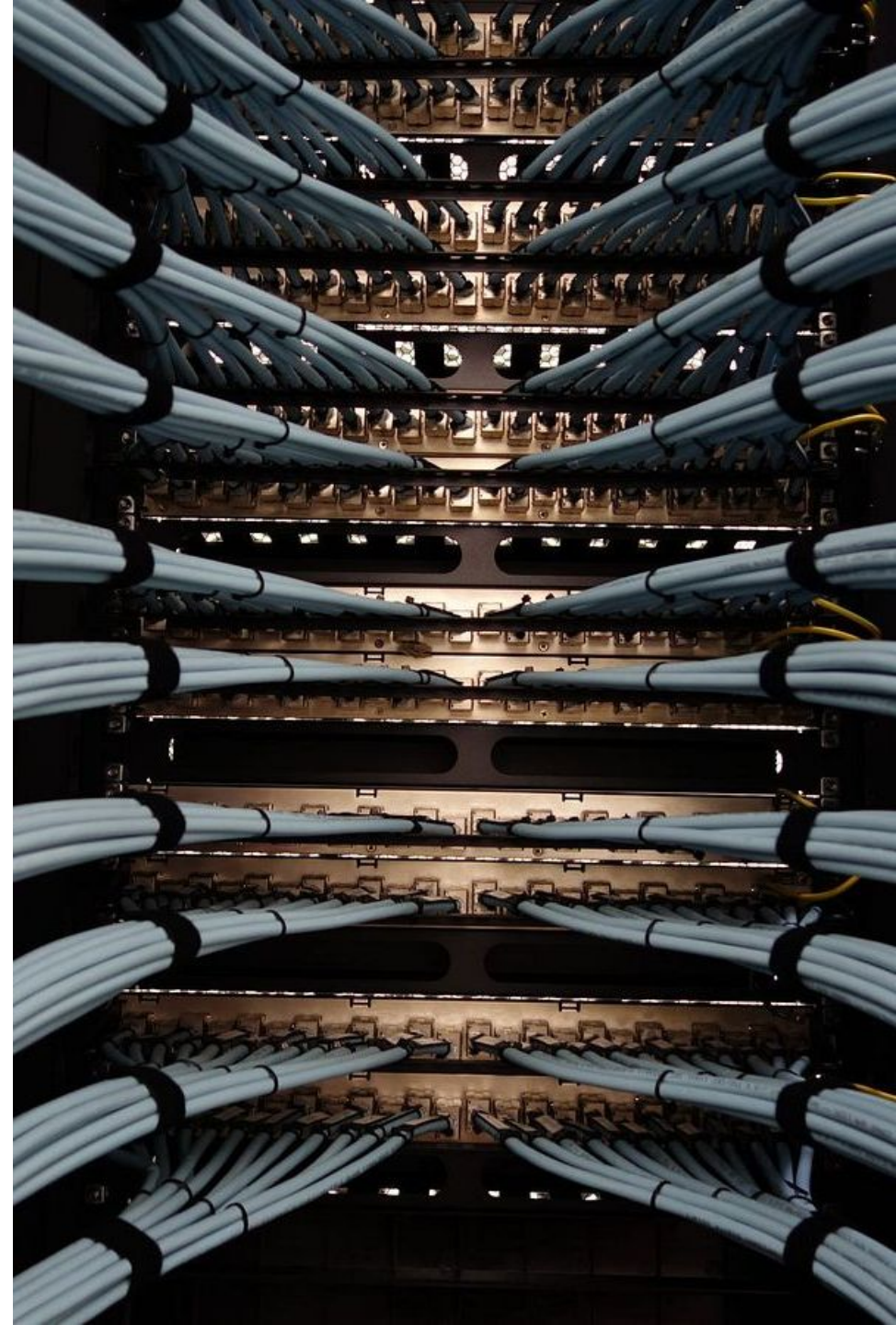
La limite honnête

Un attaquant devenu root efface les traces locales.

D'où l'export vers un collecteur distant — hors périmètre de ce module, mais c'est la suite logique.

SÉANCE 5

Le modèle de sécurité Windows



Le jeton d'accès

L'objet central de tout le modèle Windows.

Il porte le **SID** (Security Identifier — identifiant de sécurité) de l'utilisateur, les SID de ses groupes, et la liste de ses privilèges.

Toute décision d'accès confronte un jeton à une **ACL** (Access Control List — liste de contrôle d'accès).

Privilège n'est pas permission

Privilège

une capacité système : SeDebugPrivilege,
SeBackupPrivilege

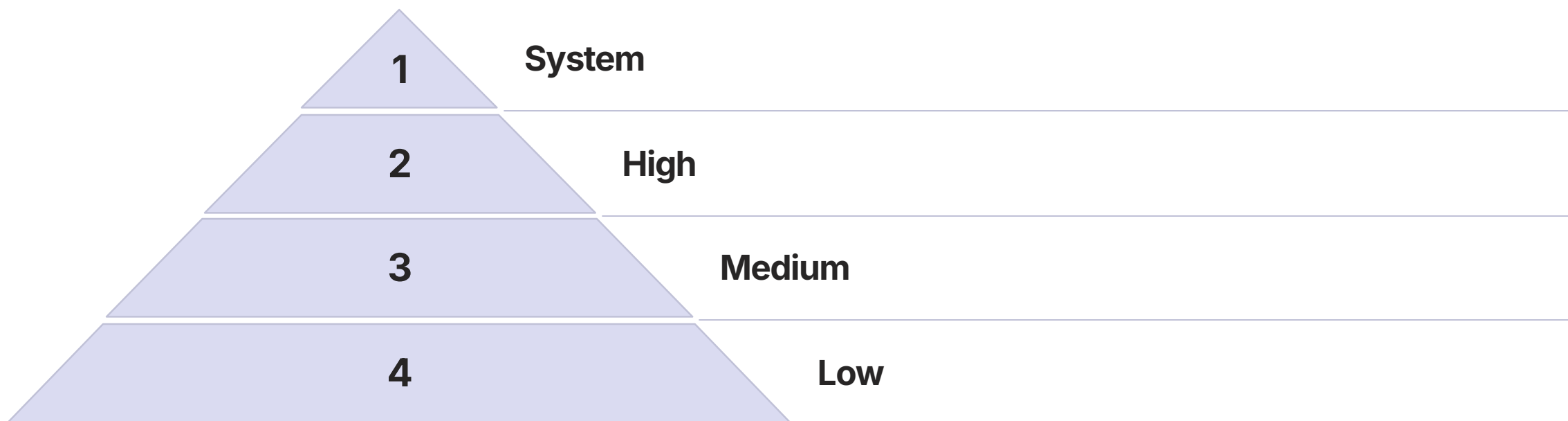
Permission

un droit sur un objet donné

L'équivalent conceptuel des capabilities Linux.

Niveaux d'intégrité obligatoires

MIC (Mandatory Integrity Control — contrôle d'intégrité obligatoire)



Un processus ne peut pas écrire vers un niveau supérieur au sien. C'est le socle du bac à sable des navigateurs.

UAC : deux jetons

UAC (User Account Control — contrôle de compte d'utilisateur)

Un compte administrateur ouvre sa session avec deux jetons : un filtré, un complet.

L'élévation bascule de l'un à l'autre.

Ce que Microsoft dit de l'UAC

L'UAC n'est pas une frontière de sécurité.

Donc la bonne question n'est pas « UAC activé ou non ».

❏ Elle est : **le compte quotidien est-il administrateur ?**

LSASS

LSASS (Local Security Authority Subsystem Service)

Le processus qui détient les secrets d'authentification en mémoire.

⊗ Cible numéro un de toute compromission de poste.

Trois couches autour de LSASS

1 RunAsPPL

(Protected Process Light — processus protégé) — protège le processus

2 Credential Guard

isole les secrets par virtualisation

3 Protected Users

restreint côté annuaire

Aucune n'est suffisante seule. Défense en profondeur, littéralement.

Antivirus, ASR, contrôle applicatif

Trois choses différentes :

Antivirus

signature et comportement

ASR

(Attack Surface Reduction —
réduction de la surface d'attaque)
— blocage de comportements
typiques d'attaque

AppLocker / WDAC

(Windows Defender Application
Control) — liste d'autorisation
d'exécution



Une règle ASR activée sans savoir ce qu'elle bloque est une régression en attente.



SÉANCE 6

Active Directory

AD n'est pas un annuaire de mots de passe

AD (Active Directory) est un **graphe de relations de confiance**.

La sécurité d'un domaine est celle du chemin le plus court vers un administrateur du domaine.

Kerberos, l'essentiel

TGT

(Ticket Granting Ticket — ticket d'octroi de tickets)

TGS

(Ticket Granting Service — service d'octroi de tickets)

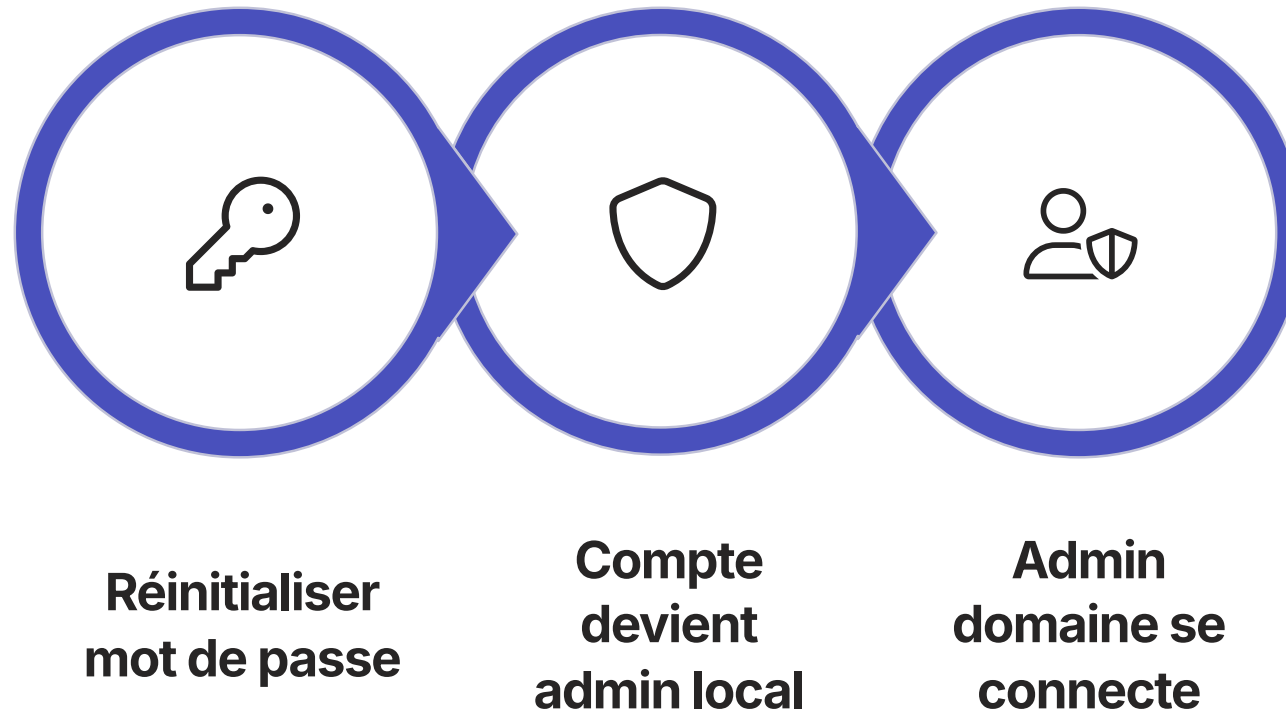
krbtgt

(Kerberos TGT — celui dont la clé signe tous les tickets du domaine)



Ce qu'il faut retenir : la compromission d'un contrôleur de domaine est terminale.

Un chemin d'attaque typique



Aucune vulnérabilité logicielle là-dedans. Uniquement des permissions légitimes mal agencées.

Le modèle en tiers

1

Tier 0

contrôleurs de domaine et administration du domaine

2

Tier 1

serveurs et applications

3

Tier 2

postes de travail

⊗ Pas d'ouverture de session descendante. Jamais.

LAPS

LAPS (Local Administrator Password Solution)

Un mot de passe administrateur local unique par poste, généré et renouvelé automatiquement.

Casse la propagation latérale d'un poste à l'autre.

SÉANCE 7

Démonstrations et bilan



Ce qu'on démontre



Un accès refusé



Une trace produite



Une adresse qui change

L'efficacité d'une défense.

Ce qu'on ne démontre pas

Le rejeu d'un exploit.

❏ Un exploit recopié ne prouve aucune compréhension et ne rapporte aucun point.

Le cadre est strict

Votre machine virtuelle isolée. Rien d'autre.

- ⊗ Accès et maintien frauduleux dans un système de traitement automatisé de données : articles 323-1 et suivants du code pénal.

Ce que nous n'avons pas couvert

Détection et réponse à incident

Sécurité des conteneurs et de l'orchestration

Systèmes embarqués

Gestion de parc à grande échelle

Vous savez maintenant durcir. Vous ne savez pas encore surveiller.



ÉVALUATION

Évaluation

Deux travaux notés

	TP 1	TP 2
Système	Debian 12	Windows 11
Lancement	Séance 4	Séance 5
Rendu	Avant la séance 5	Fin de séance 7

Individuels. Moyenne des deux.

La contrainte qui compte

Chaque sujet impose un service métier qui doit rester fonctionnel.

⊗ S'il ne répond plus au moment de la correction : **note plafonnée à 8/20**.

Un serveur éteint est parfaitement sécurisé et parfaitement inutile.

Décomposition de la note

12

Points techniques

score du script de vérification, que vous avez entre les mains

Bonus — démonstration de défense, partie annuaire

8

Points audit

justifications, mesures écartées, qualité du script, rapport

Vous connaissez votre note avant de rendre

Le script de correction vous est remis avec le sujet.

Lancez-le autant de fois que vous voulez.

Le critère que les étudiants oublient

Les mesures que vous avez volontairement écartées.

Un administrateur qui applique un benchmark sans discernement casse la production.

 On attend de vous que vous sachiez dire non, et expliquer pourquoi.

Glossaire des sigles

Sigle	Développé
ACL	Access Control List — liste de contrôle d'accès
AD	Active Directory
AIDE	Advanced Intrusion Detection Environment
ANSSI	Agence nationale de la sécurité des systèmes d'information
ASLR	Address Space Layout Randomization
ASR	Attack Surface Reduction
CFI	Control Flow Integrity
CIS	Center for Internet Security
DAC	Discretionary Access Control
DISA STIG	Defense Information Systems Agency — Security Technical Implementation Guide
GPO	Group Policy Object — objet de stratégie de groupe
LAPS	Local Administrator Password Solution
LSASS	Local Security Authority Subsystem Service
LUKS	Linux Unified Key Setup
MAC	Mandatory Access Control — contrôle d'accès obligatoire
MIC	Mandatory Integrity Control
NX	No eXecute
PAM	Pluggable Authentication Modules
PPL	Protected Process Light
SELinux	Security-Enhanced Linux
SID	Security Identifier
SUID	Set User ID
TGT / TGS	Ticket Granting Ticket / Service
UAC	User Account Control
UID	User Identifier
WDAC	Windows Defender Application Control